Threat-model an AI application

AI security · University · Lesson 1



In this lesson you will

- Draw an AI app's data flows and trust boundaries.
- Find threats at each boundary with STRIDE, and rank them.
- Shrink the blast radius by design.

Remember

- The model is not a trust boundary: its context steers its tools.
- STRIDE: spoofing, tampering, repudiation, disclosure, denial of service, elevation.
- Design fixes beat prompt fixes: remove tools, read-only, approval in code.

Threat-model in twenty minutes

1. Draw (6 min): Every part of the app and every data flow.
2. Boundaries (4 min): Circle where outside data comes in.
3. STRIDE (6 min): One threat per letter, scored likelihood × impact.
4. Fix (4 min): The one change that shrinks the blast radius most.

Use an app you are building, or a made-up design. Never probe someone else's live system.

Let’s discuss

1. Why isn't the model a trust boundary?
2. Which STRIDE letter was hardest to find a threat for?
3. What can your app do that its job doesn't need?

Check yourself

- Name one path from untrusted text to an action in your app, and the change that would cut it.